TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Android November bulletin fixes critical zero-click RCE candidate among 216 flaws

From **Cybersecurity Briefing** · Covering 2026-10-30 to 2026-11-04 (US, Global, Industry and patches: last 24 hours, with the hard cutoff at 2026-10-30; Indianapolis and Indiana: five days) · Briefing generated 2026-11-04

REPORT ID	VERSION	HANDLING
CTI-20261104-06	1.0 · 2026-11-04 13:03 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-11-04	No update
CVES	**ANALYST**	
CVE-2026-58868, CVE-2026-58876 (CVSS 9.8), CVE-2026-58936 (CVSS 9.8), CVE-2026-58882	Nick Sturgeon	

VULNERABILITY | CRITICAL | PATCH AVAILABLE; NO EXPLOITATION REPORTED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

Google published the November 2026 Android Security Bulletin on November 2. Our count of its tables confirms the reported totals of 216 CVEs and 23 Critical ratings [S1] [S2]. The lead issue is CVE-2026-58868, a heap buffer overflow in onOutputReceived of FrameDecoder.cpp that Google rates as Critical remote code execution with no user interaction on Android 14 through 17 [S2] [S3]. Two more Critical RCE flaws in the System component accompany it: CVE-2026-58876, a use-after-free also delivered through the Media Codecs Google Play system update, and CVE-2026-58936, a use-after-free in png_set_tRNS of pngset.c. CISA's enrichment scores both 9.8 [S2] [S5] [S6]. CVE-2026-58868 has no published CVSS score, and NVD lists it as awaiting analysis [S3] [S10].

The most immediately usable flaw is the Critical denial of service CVE-2026-58882 in decodeWapPdu. An independent researcher's "SMS of Death" write-up, published October 29, describes a malformed WAP Push data SMS that crashes com.android.phone, ends active calls including emergency calls, leaves no inbox entry and can cause boot loops. A proof-of-concept app is public [S1] [S11]. Coverage says the records do not formally tie the CVE to that research [S1]. We assess that they are the same bug: the bulletin's reference for CVE-2026-58882 (A-517376969) matches the bug ID in the AOSP fix commit,

b/517376969 [S2] [S12]. The researcher reports reproducing the crash on Android 12 through 16 and says Android 12 and 13 get no fix [S11].

No exploitation is reported. None of the checked CVEs appear in the CISA KEV catalog dated November 3, CISA's SSVC data marks exploitation as none where present, and MediaTek says it knows of no active exploitation of its issues [S3] [S5] [S6] [S8] [S14]. The Android bulletin itself is silent on exploitation, so it should not be read as stating that none occurred [S2]. Severity also needs context. Google's rating assumes platform protections are off or bypassed, and no source explains how an attacker reaches FrameDecoder [S1] [S2]. The kernel Bluetooth flaws and the MediaTek modem flaws we checked need an attacker on an adjacent network or a rogue base station, and they score 7.5 to 8.8 in the CVE records despite their Critical bulletin ratings [S15] [S16] [S17] [S18] [S19].

Update Android fleets to patch level 2026-11-05, which covers every issue in the bulletin. The 2026-11-01 level covers only the Android Runtime, Framework and System issues [S2]. Rollout depends on the phone maker: Samsung has published its November package, while Google's Pixel bulletin index still showed October when we checked [S13] [S25]. No workaround exists for phones that cannot update yet [S1]. Find Android 13 and older devices now, because they are outside the listed fixes. Do not count the October patch level as proof of protection against CVE-2026-58882 until sources agree, since the researcher and Google's November bulletin place the fix in different months [S2] [S11].

Key judgments

UNLIKELY · MODERATE CONFIDENCE

CVE-2026-58868 is unlikely to be added to the CISA KEV catalog within 30 days of the bulletin. There is no exploitation signal, EPSS is low (0.00211), and the reachable attack path is undocumented. That path remains the main uncertainty. [S2] [S3] [S8] [S9]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE

Credible public reporting of real-world abuse of the WAP Push denial of service within 90 days is a roughly even chance. The bug is cheap to trigger, needs only a phone number and has a public proof of concept, but carrier handling of these messages is undocumented and the impact is disruption rather than compromise. [S1] [S11] [S21]

VERY LIKELY · MODERATE CONFIDENCE

A substantial share of managed Android fleets will very likely remain below patch level 2026-11-05 thirty days after the bulletin, because maker and carrier schedules vary and the two-level structure lets devices ship at the lower level. We have no fleet measurement behind this estimate. [S1] [S2] [S13] [S25]

VERY LIKELY · MODERATE CONFIDENCE

Android 12 and 13 devices will very likely stay exposed to the WAP Push crash unless they are replaced or a maker ships its own backport. The researcher reports the bug on those versions and the CVE record lists only Android 14 through 17 as affected. [S1] [S4] [S11] [S20]

> LIKELY · MODERATE CONFIDENCE
> Public root-cause analysis of at least one Critical RCE in this bulletin is likely within 30 days, because Google committed to publishing source patches to AOSP, which makes patch comparison practical. This would narrow the current gap on reachability and could shorten the safe patching window. [S2] [S3]

INDICATORS OF COMPROMISE

No network indicators (IPs, domains, hashes, sender numbers) were published in any source, and no campaign is reported. The entries below are crash-triage artifacts and code locations from the researcher's October 29 write-up, the AOSP commit, the CVE records and the AOSP source tree, useful for triaging affected phones rather than for blocking.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
port	`2948`	WAP Push port listed in the write-up as the delivery vector for the malformed SMS.	REPORTED	2026-10-29	[S11]
other	`destination_port=134020`	Value the write-up uses to identify the poison rows in the raw SMS queue; the write-up does not reconcile it with port 2948. Analyst note: 134020 equals 2948 plus 131072 (bit 17), so it may be port 2948 with an internal flag set. That reading is our inference and is unverified.	REPORTED	2026-10-29	[S11]
other	`com.android.phone`	Android telephony process that crashes. Repeated restarts are the main symptom.	REPORTED	2026-10-29	[S1] [S11]
other	`java.lang.NegativeArraySizeException`	Uncaught exception in the crash signature, thrown from WapPushOverSms.decodeWapPdu.	REPORTED	2026-10-29	[S11]
other	`FATAL EXCEPTION: main`	Logcat string paired with Process: com.android.phone in the crash signature. It is generic on its own, so match it together with the exception and process name.	REPORTED	2026-10-29	[S11]
other	`DisconnectCause CS_DEATH`	Call-disconnect reason logged when active calls drop because of the crash.	REPORTED	2026-10-29	[S11]
other	`dispatchWapPdu / InboundSmsHandler`	Stack frames on the path to decodeWapPdu in the reported crash.	REPORTED	2026-10-29	[S11]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`content://sms/raw`	Pending inbound SMS queue where the write-up says the poison message stays and is retried at boot. Benign on its own; relevant during triage of a boot loop.	REPORTED	2026-10-29	[S11]
filepath	`src/java/com/android/internal/telephony/WapPushOverSms.java`	File changed by the fix for b/517376969 in the frameworks/opt/telephony repository; contains decodeWapPdu.	REPORTED	2026-08-05	[S4] [S12]
filepath	`src/java/com/android/internal/telephony/InboundSmsHandler.java`	Second production file changed by the same fix.	REPORTED	2026-08-05	[S12]
filename	`FrameDecoder.cpp`	Source file with the heap overflow in onOutputReceived (CVE-2026-58868). Useful when reading native crash reports; no crash signature has been published.	REPORTED	2026-11-02	[S3]
filepath	`frameworks/av/media/libstagefright/FrameDecoder.cpp`	Likely location of the CVE-2026-58868 flaw. The bulletin names no repository; we matched the file and function names to the AOSP tree, where onOutputReceived is defined in the video-frame and image decoder classes. Not confirmed as the patched file until Google publishes the AOSP link.	DERIVED		[S2] [S3] [S28]
filename	`pngset.c`	Source file with the use-after-free in png_set_tRNS (CVE-2026-58936).	REPORTED	2026-11-02	[S6]
filename	`PduParser.java`	Source file with the integer overflow in parseContentType (CVE-2026-58814), a Critical remote denial of service.	REPORTED	2026-11-02	[S7]
filepath	`net/bluetooth/rfcomm/sock.c`	Kernel file for the use-after-free involving rfcomm_connect_ind (CVE-2026-53256).	REPORTED	2026-06-25	[S18]
filepath	`net/bluetooth/sco.c`	Kernel file for the use-after-free race in sco_conn_ready (CVE-2026-89774).	REPORTED	2026-09-16	[S19]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

No attacks are reported, so everything here describes possible use, not observed activity. CVE-2026-58868 is a heap overflow in media frame decoding rated as zero-click RCE, but no source documents how an attacker's content reaches it [S1] [S3]. The flawed code sits in the AOSP class that extracts video frames and still images, so crafted media is a plausible input; that is our inference, not a reported vector [S28]. CVE-2026-58882 is better understood. Per the write-up, an attacker sends a malformed WAP Push data SMS whose WSP header length becomes negative after a 32-bit cast, throwing an uncaught exception on the main telephony thread. The phone process dies, active calls drop, service is lost for one to two seconds, and carrier redelivery plus retries at boot can extend the disruption or cause a boot loop [S11]. Google's fix catches the exception and deletes the offending message rather than adding the range check the researcher proposed [S11] [S12]. The kernel Bluetooth flaws require adjacent access, and the MediaTek modem flaws we checked require the phone to connect to an attacker-controlled base station [S15] [S16] [S17] [S18] [S19].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Execution	T1658 Exploitation for Client Execution	Potential only: crafted content triggers memory corruption in media or image handling (CVE-2026-58868, CVE-2026-58876, CVE-2026-58936) with no user interaction. The delivery path is not documented. [S2] [S3] [S5] [S6] [S29]	Review native crash reports for media processes that reference FrameDecoder or PNG code; send suspect device reports to a mobile threat defense vendor. Patch level is the more dependable control.
Impact	T1642 Endpoint Denial of Service	A malformed WAP Push SMS sent to a known phone number crashes com.android.phone, drops active calls, and can cause repeated crashes or a boot loop (CVE-2026-58882). CVE-2026-58814 is a separate Critical remote DoS. [S4] [S7] [S11] [S30]	Look for the NegativeArraySizeException signature and CS_DEATH disconnects in logcat or bug reports; track help desk reports of unexplained call drops and boot loops.
Privilege Escalation	T1404 Exploitation for Privilege Escalation	Potential only: kernel flaws such as the Bluetooth use-after-free bugs, plus modem out-of-bounds writes, are rated as privilege escalation. The bulletin describes the top kernel issue as remote escalation with no added privileges. [S2] [S15] [S18] [S19] [S31]	Limited on-device visibility. Use Play Integrity results and mobile threat defense alerts where deployed, and review kernel crash data in bug reports.

Tactic	Technique	Procedure observed	Detection opportunity
Collection	T1638 Adversary-in-the-Middle	Potential only: an attacker runs a rogue base station that the phone connects to, the stated precondition for the MediaTek modem flaws we checked. This access step would precede modem exploitation. [S15] [S16] [S17] [S32]	Mobile threat defense or cellular anomaly tools, where available, can flag unexpected network downgrades or suspect cells. Most fleets have no native visibility here.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

Android devices below the required patch level (fleet exposure) `KQL`

```
// MdmAndroidInventory_CL is a placeholder for your MDM inventory export.
// In Microsoft Graph, the managedDevice property androidSecurityPatchLevel can supply PatchLevel_s.
MdmAndroidInventory_CL
| extend PatchDate = todatetime(PatchLevel_s)
| extend OsMajor = toint(split(OsVersion_s, '.')[0])
| extend Exposure = case(
    isnull(PatchDate), 'Unknown',
    OsMajor <= 13, 'Android 13 or older: outside listed fixes',
    PatchDate < datetime(2026-11-01), 'Below 2026-11-01: lead RCE and WAP Push DoS open',
    PatchDate < datetime(2026-11-05), 'Below 2026-11-05: kernel and chipset issues open',
    'At 2026-11-05 or later')
| summarize Devices = dcount(DeviceId_s) by Exposure, Manufacturer_s, Model_s
| order by Devices desc
```

Table and field names are placeholders. This is the most useful query for this item: it measures exposure rather than attack activity. Patch-level dates can reach devices before a maker ships every fix, so check maker bulletins as well.

WAP Push crash signature in collected Android logs `SPLUNK SPL`

```
index=mobile sourcetype=android:logcat "com.android.phone" ("NegativeArraySizeException" OR
"decodeWapPdu" OR "CS_DEATH")
| bin _time span=1h
| stats count AS events values(host) AS devices BY _time, host
| where events >= 1
| sort - events
```

Index, sourcetype and host field are placeholders. Most MDM deployments do not collect logcat, so this usually applies to bug reports captured from dedicated or high-risk devices. Each match should be treated as a lead, not as proof of attack; a malformed message may also come from a misbehaving source.

Android telephony crash from WapPushOverSms `SIGMA`

```
title: Android Telephony Crash From Malformed WAP Push
status: experimental
description: Detects the reported crash signature for a malformed WAP Push SMS in com.android.phone
logsource:
  product: android
  service: logcat
detection:
  selection_process:
    message|contains: 'com.android.phone'
  selection_exception:
    message|contains:
      - 'NegativeArraySizeException'
      - 'WapPushOverSms.decodeWapPdu'
  condition: selection_process and selection_exception
falsepositives:
  - Researcher or internal testing
  - Malformed WAP Push traffic with no hostile intent
level: medium
```

Built from the researcher's published signature; no sample logs were available. The logsource is custom and needs mapping to your pipeline. Logcat lines may split the process name and the exception across entries, so correlate by device and short time window if needed.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Android Framework (FrameDecoder.cpp)	Android 14, 15, 16, 16-qpr2, 17	Patch level 2026-11-01 or later	CVE-2026-58868	Not published (SSVC: automatable yes, technical impact total)	0.00211 (11th percentile, 2026-11-04)	No	N/A
Android System (Media Codecs Google Play system update also lists the fix)	Android 14, 15, 16, 16-qpr2, 17	Patch level 2026-11-01 or later; also listed in Google Play system updates	CVE-2026-58876	9.8 (CISA ADP)	0.00172 (7th percentile, 2026-11-04)	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Android System (pngset.c)	Android 14, 15, 16, 16-qpr2, 17	Patch level 2026-11-01 or later	CVE-2026-58936	9.8 (CISA ADP)	0.00172 (7th percentile, 2026-11-04)	No	N/A
Android System (WAP Push, decodeWapPdu)	Android 14, 15, 16, 16-qpr2, 17 per CVE record; researcher also reports Android 12 and 13	Patch level 2026-11-01 or later per Google; researcher states October 2026 update. No listed fix for Android 12 or 13	CVE-2026-58882	Not published	0.00188 (9th percentile, 2026-11-04)	No	N/A
Android System (PduParser.java)	Android 14, 15, 16, 16-qpr2, 17	Patch level 2026-11-01 or later	CVE-2026-58814	Not published	0.00168 (6th percentile, 2026-11-04)	No	N/A
Android System (other Critical privilege escalation)	CVE-2026-55275 and CVE-2026-55283: Android 16, 16-qpr2, 17. CVE-2026-58984: Android 15, 16, 16-qpr2, 17	Patch level 2026-11-01 or later	CVE-2026-55275, CVE-2026-55283, CVE-2026-58984	Not reviewed	Not retrieved	No	N/A
Android kernel, Bluetooth	Devices using affected kernels; see upstream kernel commits	Patch level 2026-11-05 or later	CVE-2026-53256, CVE-2026-89774	8.0 and 8.8 (adjacent network)	0.00264 and 0.00403 (18th and 35th percentile, 2026-11-04)	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Android kernel, pKVM and HID	Devices using affected kernels	Patch level 2026-11-05 or later	CVE-2026-59044, CVE-2026-59045, CVE-2026-59048, CVE-2026-80604	Not reviewed	Not retrieved	No	N/A
MediaTek modem	Many MT-series chipsets; see the MediaTek bulletin per CVE	Patch level 2026-11-05 or later	CVE-2026-20499, CVE-2026-20519, CVE-2026-20520, CVE-2026-20545 through CVE-2026-20549	7.5 on the three records checked (CVE-2026-20499, CVE-2026-20519, CVE-2026-20545); others not reviewed	CVE-2026-20499: 0.00242 (15th percentile); others not retrieved	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Qualcomm closed-source component	Not determined; Qualcomm bulletin could not be retrieved	Patch level 2026-11-05 or later	CVE-2026-25285	Unknown	Not returned	No	N/A

Immediate (0–24 hours)

- Export all Android devices from MDM with OS version, patch level, maker and model, then group them: Android 13 or older; below 2026-11-01; below 2026-11-05; at 2026-11-05 or later. `IT OPS` [S2] [S26]
- Push available updates to managed devices, starting with devices used by executives, on-call staff, field staff and anyone who relies on the phone for emergency calls. `IT OPS` [S1] [S2] [S13]
- Brief the help desk on the WAP Push symptoms: unexplained dropped calls, repeated one-to-two-second service loss, boot loops and no visible message. Escalate these cases to the SOC and capture a bug report if the device allows it, before any reset. `SOC` [S11]
- Treat 2026-11-01 as the minimum evidence of a fix for CVE-2026-58882, and do not credit the October level until sources agree. `SOC` [S2] [S11]

Short term (1–7 days)

- Set the MDM minimum security patch level to 2026-11-05 once maker builds are available, starting in report mode with a grace period so that devices without an offered update are not locked out. In Intune, use the Minimum security patch level compliance setting. `IT OPS` [S2] [S26]
- Track maker release status by model: Samsung's November package is published, and the Pixel bulletin should be rechecked. Record which models have no offered build, and confirm Samsung's status for CVE-2026-20499, which it says was fixed earlier. `IT OPS` [S13] [S25]
- Check both the Android security update date and the Google Play system update date. CVE-2026-58876 is on the Play system update list, but CVE-2026-58868 is not, so a current Play system update alone does not prove a fix for it. `IT OPS` [S1] [S2] [S27]
- Ask makers of Android 12 and 13 devices, including rugged and kiosk models, whether they have backported the WAP Push fix. Tie the replacement of any device without a backport to a dated plan. `IT OPS` [S1] [S11] [S20]
- Write a boot-loop recovery runbook. The researcher's recovery uses ADB to clear the poison message, but USB debugging is disabled by default on fully managed Android Enterprise devices, so plan for spare devices and re-enrollment. Reports also say a factory reset may give only temporary relief because the carrier can redeliver the message. `IT OPS` [S11] [S21] [S26]
- Add the rule that reviews this bulletin's AOSP links and any new technical analysis when published, and re-rank priorities if the FrameDecoder attack path is shown to be reachable through common messaging or

media apps. SOC [S2]

Long term

- Set a mobile patching standard with a target number of days to reach the second monthly patch level, and report compliance to leadership each month. LEADERSHIP [S2] [S26]
- Buy Android devices only from makers with published, multi-year security update commitments, and retire devices before updates end. LEADERSHIP [S1] [S11]
- Treat chipset and modem fixes as part of device risk. Keep model and chipset data in inventory so that MediaTek and Qualcomm bulletins can be matched to the fleet quickly. IT OPS [S2] [S14]

Workarounds & compensating controls

- Use Conditional Access or equivalent to limit corporate data access from devices that stay below the required patch level after the grace period. This reduces data exposure but does not fix the flaw. IT OPS [S26]
- Give staff who rely on a phone for safety or emergency response a second way to reach help, such as a desk phone, radio or second device on another platform, until their devices are patched. No workaround for the flaws has been published. LEADERSHIP [S1] [S11]
- Turn off Bluetooth on high-risk unpatched devices where the business allows it, since the Critical Bluetooth flaws require adjacent access. Analyst recommendation, not vendor guidance. IT OPS [S18] [S19]
- Where MDM or the device supports it, disable 2G on high-risk devices to reduce rogue base station risk. This is a partial analyst recommendation: the records do not say which radio generations the attack needs, and one report notes Android 17's 2G protections do not stop the WAP Push crash. IT OPS [S15] [S20]
- Keep Google Play Protect on and require a Play Integrity check through MDM. These controls help against harmful apps and tampered devices, but do not fix the remote flaws in this bulletin. IT OPS [S2] [S26]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: Google patches critical Android flaw (November 2026 bulletin coverage)
Published 2026-11-04 · B1 Usually reliable, confirmed by other sources
Briefing source. Totals and CVE details match the bulletin. Its statement that Google's bulletin reported no attacks goes further than the bulletin text, which is silent on exploitation.

[S2] Google Android: Android Security Bulletin: November 2026
Published 2026-11-02 · A1 Completely reliable, confirmed by other sources
Primary source. Version 1.0 with no AOSP links for the lead issues when read on 2026-11-04.

[S3] CVE Program: CVE-2026-58868 record
Published 2026-11-02 · **A1** Completely reliable, confirmed by other sources
Primary record with CISA SSVC data; no CVSS or CWE.

[S4] CVE Program: CVE-2026-58882 record
Published 2026-11-02 · **A2** Completely reliable, probably true
Primary record. Describes an out-of-bounds read from integer overflow, which differs from the researcher's negative-array crash description.

[S5] CVE Program: CVE-2026-58876 record
Published 2026-11-02 · **A1** Completely reliable, confirmed by other sources
CVSS 9.8 and CWE-416 from CISA ADP.

[S6] CVE Program: CVE-2026-58936 record
Published 2026-11-02 · **A1** Completely reliable, confirmed by other sources
CVSS 9.8 and CWE-416 from CISA ADP.

[S7] CVE Program: CVE-2026-58814 record
Published 2026-11-02 · **A1** Completely reliable, confirmed by other sources
Second Critical remote DoS.

[S8] CISA: Known Exploited Vulnerabilities catalog (version 2026.11.03)
Published 2026-11-03 · **A1** Completely reliable, confirmed by other sources
The list is newest first. We reviewed entries back to September 2025, which spans the publication dates of the checked CVEs, and found none of them.

[S9] FIRST: EPSS API results for the CVEs in this report
Published 2026-11-04 · **A2** Completely reliable, probably true
A second query covered CVE-2026-58814, CVE-2026-89774, CVE-2026-53256 and CVE-2026-20499. It returned no data for CVE-2026-25285.

[S10] NVD: CVE-2026-58868 API record
Published 2026-11-02 · **A1** Completely reliable, confirmed by other sources
Awaiting Analysis; no CVSS or CWE.

[S11] Mark B (independent researcher): SMS of Death write-up
Published 2026-10-29 · **C2** Fairly reliable, probably true
Original research; the core bug is corroborated by the AOSP commit. The author's track record is unknown, and test results and persistence claims have not been independently reproduced in the sources reviewed. We did not open the proof-of-concept code.

[S12] Android Open Source Project: Commit 735d967: Fix remote DoS in decodeWapPdu (b/517376969)
Published 2026-08-05 · **A1** Completely reliable, confirmed by other sources
Primary source for the fix and its bug ID. Authored 2026-06-15, committed 2026-08-05. Includes Flag: EXEMPT CVE_FIX.

[S13] Samsung Mobile Security: Security Maintenance Release, November 2026 (SMR Nov-2026 Release 1)
Published 2026-11-03 · **A1** Completely reliable, confirmed by other sources
Lists 20 Critical Google-bulletin CVEs. Says CVE-2026-20499 and CVE-2026-25301 were fixed in earlier releases. Rollout by model is not stated.

[S14] MediaTek: Product Security Bulletin, November 2026
Published 2026-11-02 · **A1** Completely reliable, confirmed by other sources
Primary source; six Critical modem CWE-787 issues and a no-known-exploitation statement.

[S15] CVE Program: CVE-2026-20545 record
Published 2026-11-02 · **A1** Completely reliable, confirmed by other sources
Requires connection to a rogue base station; CVSS 7.5 from CISA ADP.

[S16] CVE Program: CVE-2026-20499 record
Published 2026-11-02 · **A1** Completely reliable, confirmed by other sources
Requires connection to a rogue base station; CVSS 7.5 from CISA ADP.

[S17] CVE Program: CVE-2026-20519 record
Published 2026-10-05 · **A1** Completely reliable, confirmed by other sources
References MediaTek's October 2026 bulletin, though it appears in the November Android bulletin.

[S18] CVE Program: CVE-2026-53256 record
Published 2026-06-25 · **A1** Completely reliable, confirmed by other sources
Linux kernel RFCOMM use-after-free; CVSS 8.0, adjacent network, low privileges.

[S19] CVE Program: CVE-2026-89774 record
Published 2026-09-16 · **A1** Completely reliable, confirmed by other sources
Linux kernel SCO use-after-free; CVSS 8.8, adjacent network. The record's version data is partly inconsistent.

[S20] Born City: Android-Schwachstelle: 20 SMS können Smartphones in Neustart-Schleifen zwingen
Published 2026-10-30 · **C2** Fairly reliable, probably true
Secondary coverage; reports no real-world attacks and Google's non-security classification.

[S21] CyberInsider: SMS of Death coverage
Published 2026-10-29 · **C2** Fairly reliable, probably true
Secondary coverage with an update naming CVE-2026-58882; the body says no CVE, so it is internally inconsistent.

[S22] Braindetox: Android WAP Push SMS DoS: Calls Drop, October 2026 Patch
Published 2026-10-30 · **F3** Reliability cannot be judged, possibly true
Unnamed author. Suggests CVE-2026-58865 as a possible match, which the bug ID comparison does not support.

[S23] DigitalToday: Android SMS vulnerability can drop calls
Published 2026-10-30 · **C3** Fairly reliable, possibly true
Secondary coverage. Names the researcher differently from other sources.

[S24] Google Android: Android Security Bulletin: October 2026
Published 2026-10-05 · **A1** Completely reliable, confirmed by other sources
Checked for the WAP Push fix: no WAP Push reference and no CVE-2026-58882.

[S25] Google Android: Pixel Update Bulletins index
Published 2026-10-06 · **A2** Completely reliable, probably true
Date is the newest listed entry (October 2026). No November entry when checked on 2026-11-04; the page may lag.

[S26] Microsoft Learn: Android Enterprise compliance settings in Microsoft Intune
Published 2026-06-18 · **A1** Completely reliable, confirmed by other sources
Source for the patch-level and Play Integrity compliance settings and the USB debugging default.

[S27] Google: Check and update your Android version
Published · **A1** Completely reliable, confirmed by other sources
User steps for checking the security update and Google Play system update. Page shows no publication date.

[S28] Android Open Source Project: FrameDecoder.cpp source file (main branch)
Published · **A2** Completely reliable, probably true
Used only to understand the file's role and likely path. Not confirmed as the patched location. Viewed the current main branch, not a dated release.

[S29] MITRE ATT&CK: T1658 Exploitation for Client Execution (Mobile)
Published · **A1** Completely reliable, confirmed by other sources
Technique reference only.

[S30] MITRE ATT&CK: T1642 Endpoint Denial of Service (Mobile)
Published · `A1` Completely reliable, confirmed by other sources
Technique reference only.

[S31] MITRE ATT&CK: T1404 Exploitation for Privilege Escalation (Mobile)
Published · `A1` Completely reliable, confirmed by other sources
Technique reference only.

[S32] MITRE ATT&CK: T1638 Adversary-in-the-Middle (Mobile)
Published · `A1` Completely reliable, confirmed by other sources
Technique reference only; the page names rogue base stations.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-05-05	Researcher reports the WAP Push crash to Google's vulnerability reward program.	[S11]
2026-06-15	Google engineer authors the fix for b/517376969.	[S12]
2026-08-05	Fix commit 735d967 is committed in AOSP telephony code.	[S12]
2026-10-05	October Android bulletin is published with no WAP Push reference; the researcher says the fix shipped in October updates.	[S11] [S24]
2026-10-29	"SMS of Death" write-up goes public. Reports say Google reaffirmed a non-security classification the same day.	[S11] [S20] [S21]
2026-11-02	Google publishes the November bulletin and CVE records; MediaTek publishes its November bulletin.	[S2] [S3] [S14]
2026-11-03	Samsung publishes SMR Nov-2026 Release 1. KEV catalog version 2026.11.03 does not include the checked CVEs.	[S8] [S13]
2026-11-04	The Hacker News publishes coverage; CISA ADP enrichment adds 9.8 scores to CVE-2026-58876 and CVE-2026-58936.	[S1] [S5] [S6]

Relevance to Indianapolis, Indiana & managed clients

No source reports any Indiana-specific targeting or incident. The practical concern for Indianapolis and Indiana organizations is uneven patching of Android phones and tablets. Government, public safety and healthcare groups should look first at on-call, field and home-health staff, since a reported crash can end active calls, including emergency calls. Manufacturers, warehouses and school districts should check rugged handhelds, kiosks and shared tablets, which often run older Android versions and may sit on Android 13 or below, outside the listed fixes. Small and mid-size businesses with personal phones in use may have no patch visibility at all; a work-profile compliance rule is a low-cost starting point. For managed IT service clients, run the patch-level report across every tenant, publish a by-client exposure summary, and agree on a grace period so that compliance rules do not block staff whose maker has not yet shipped a build. Rogue base station and Bluetooth attacks need physical proximity, so they matter most for executives and staff at higher-risk sites or events rather than as broad threats.

Intelligence gaps

- How an attacker reaches FrameDecoder in CVE-2026-58868 (MMS, messaging apps, media scanning or something else) is unknown, and no CVSS score is published. This is the main fact that would change priorities.
- Delivery paths for CVE-2026-58876 and CVE-2026-58936 are also undocumented.
- Which patch level first contains the WAP Push fix is disputed: the researcher reports October, while Google lists CVE-2026-58882 under 2026-11-01. Testing a device at the October level, or checking the commit against release tags, would settle it.
- Whether Android 12 and 13 are affected by the other Critical flaws is unknown; the records do not address these versions.
- Whether US carriers filter malformed WAP Push messages, and how that affects the attack, is unknown. No source describes network-side protection.
- The persistence claims (about 20 to 30 messages, database corruption, week-long disruption, limited benefit of a factory reset) come from one researcher's tests and have not been independently reproduced in the sources reviewed.
- Qualcomm's bulletin and the CVE-2026-25285 record could not be retrieved, so that Critical issue's details and affected chipsets remain unknown.
- Pixel's November bulletin and other makers' release dates were not available when checked. Watch for these, the AOSP links that Google promised within 48 hours, any KEV change and NVD scoring.

Other notes

- The bug ID match is the key analytic finding: bulletin reference A-517376969 for CVE-2026-58882 equals b/517376969 in the fix commit. It is strong evidence but not a formal Google statement. One remaining mismatch is that the CVE record describes an out-of-bounds read, while the researcher and the commit point to a crash handled by catching runtime exceptions and deleting the message.
- Sources disagree on CVE mapping: one explainer suggests CVE-2026-58865 from the October bulletin, while its own linked commit differs from 735d967. The bug ID match does not support that mapping [S4] [S12] [S22].

- Google reportedly classified the WAP Push report as non-security as late as October 29 [S20] [S21], yet the commit is labelled a remote DoS fix with a CVE_FIX flag and the November bulletin rates it Critical [S2] [S12]. No public Google statement explaining this was found.
- The Android bulletin lists eight Critical MediaTek modem CVEs, while MediaTek's November bulletin lists six. CVE-2026-20519 traces to MediaTek's October bulletin; CVE-2026-20520 is also missing from the November list and we did not open its record. Samsung lists 20 Critical CVEs rather than 23 because it omits CVE-2026-20499 (fixed earlier), CVE-2026-20519 and CVE-2026-20520 from its Critical list [S2] [S13] [S14] [S17].
- Researcher naming varies across coverage: Mark B in the write-up, Mark Blaszczyk in two reports, and a different name in another [S11] [S20] [S21] [S23]. This report uses the name in the write-up.
- Bulletin severity and CVE scoring differ for several flaws, and Google's rating assumes platform mitigations are disabled or bypassed. Use both views when ranking risk, but do not delay patching on the basis of lower CVSS scores alone [S2] [S15] [S18] [S19].
- EPSS values are low for all CVEs where data was returned, but these records are only days old, so low scores carry limited weight [S9].

CTI-20261104-06 v1.0 · Generated 2026-11-04 13:03 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.